

Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак «Ampire». Лабораторная работа № 1.

**СЦЕНАРИЙ № 5 «ЗАЩИТА НАУЧНО-ТЕХНИЧЕСКОЙ ИНФОРМАЦИИ
ПРЕДПРИЯТИЯ»**

Садова Диана Алексеевна, Диденко Дмитрий Владимирович, А6

Содержание

1	Описание сценария	5
2	Перечень уязвимостей и последствий	7
2.1	Уязвимость 1. Слабый пароль пользователя.	7
2.2	Последствие. Developer backdoor.	10
2.3	Уязвимость 2. XSS (CVE-2019-17427).	13
2.4	Последствие. Redmine User.	16
2.5	Уязвимость 3. Blind SQL (CVE-2019-18890).	17
3	Мониторинг	20
4	Вывод	21

Список иллюстраций

1.1	Описание сценария	6
2.1	Сброс пароля	8
2.2	Сброс пароля	9
2.3	Запуск исполняемого файла в планировщике	10
2.4	Путь до исполняемого файла	11
2.5	Путь до исполняемого файла	12
2.6	Пример добавления кода, выводящего на экран надпись XSS в wiki-страницу	13
2.7	При нажатии на поле wiki-страницы запускается код	13
2.8	Данный код включает REST API при выполнении с учетной записи admin	14
2.9	Содержимое файла redcloth3.rb	14
2.10	Изменения в файле redcloth3.rb Код, исправляющий уязвимость CVE-2019-17427	15
2.11	Исправление в файле redcloth3.rb	15
2.12	Успешное устранение уязвимости	16
2.13	Список пользователей Redmine	17
2.14	Удаление пользователя hacker	17
2.15	При отправке запроса SLEEP(2) время ожидания ответа возрастает до 4 секунд, что свидетельствует об инъекции	18
2.16	Нарушитель посимвольно перебирает содержимое конфиденци- ального проекта	18
2.17	Содержимое файла query.rb с исправлением уязвимости	19

Список таблиц

1 Описание сценария

Последовательность действий нарушителя следующая:

- 1) Внутренний нарушитель подбирает пароль на файловый сервер и меняет существующий на сервере файл другим файлом с backdoor (дефектом алгоритма).
- 2) Пользователь Dev-1 загружает и запускает файл с backdoor.
- 3) Внутренний нарушитель получает контроль над компьютером пользователя Dev-1 и загружает скрипт для похищения учетных данных из браузера. Запускает данный скрипт и получает логин - пароль к Redmine.
- 4) Внутренний нарушитель проводит атаку stored XSS для включения на Redmine сервере REST API. Вредоносный код записывается на Wiki-страницу проекта Dev1. Получив доступ к консоли администратора, внутренний нарушитель создает нового пользователя Redmine с правами администратора.
- 5) Внутренний нарушитель ожидает, когда администратор просмотрит страницу с внедренным вредоносным кодом.
- 6) Внутренний нарушитель проводит Blind SQL-инъекцию, получает доступ к данным конфиденциального проекта.

Ниже представлена логическая схема сценария № 5 «Защита научно-технической информации предприятия», красными стрелками обозначены

вредоносные действия нарушителя, а зелеными – легитимные действия любого пользователя (рис. 1.1).

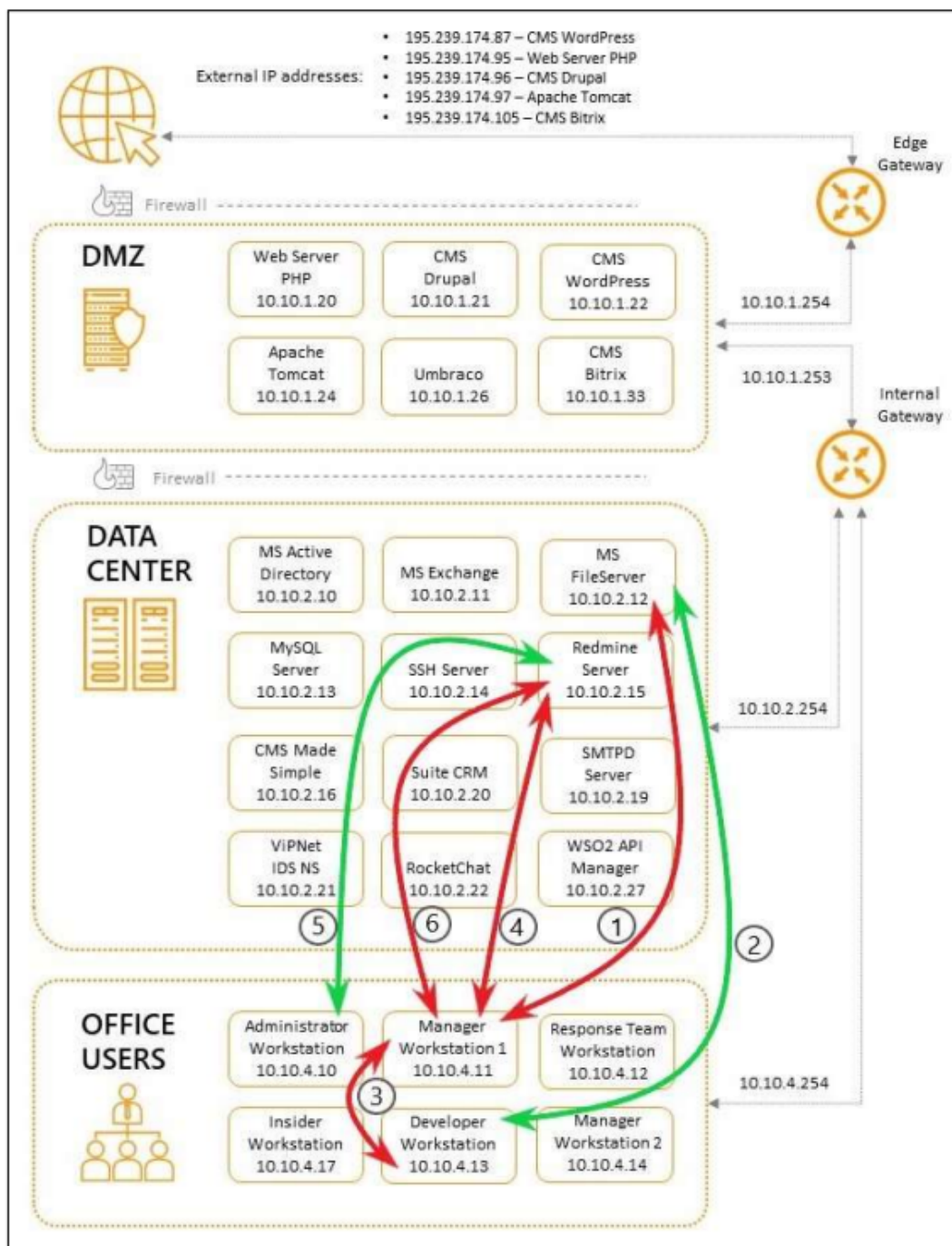


Рис. 1.1: Описание сценария

2 Перечень уязвимостей и последствий

Для сценария № 5 «Защита научно-технической информации предприятия» определены три уязвимости и два последствия:

- 1) Уязвимость 1. Слабый пароль пользователя.
- 2) Последствие. Developer backdoor.
- 3) Уязвимость 2. XSS (CVE-2019-17427).
- 4) Последствие. Redmine User.
- 5) Уязвимость 3. Blind SQL (CVE-2019-18890).

2.1 Уязвимость 1. Слабый пароль пользователя.

На файловом сервере установлен слабый пароль для входа, что позволяет нарушителю перебрать данный пароль со словарем. После успешной авторизации на файловом сервере нарушитель загружает .bat файл и получает доступ к учетным данным пользователя dev1.

Решение: для закрытия уязвимости необходимо изменить пароль на более сложный, не содержащийся в словаре. Для изменения пароля на сервере AD открыть «Active Directory Users and Computers», найти пользователя dev1, нажать на «Reset Password» (Рисунок 2) и ввести новый пароль.(рис. 2.1).

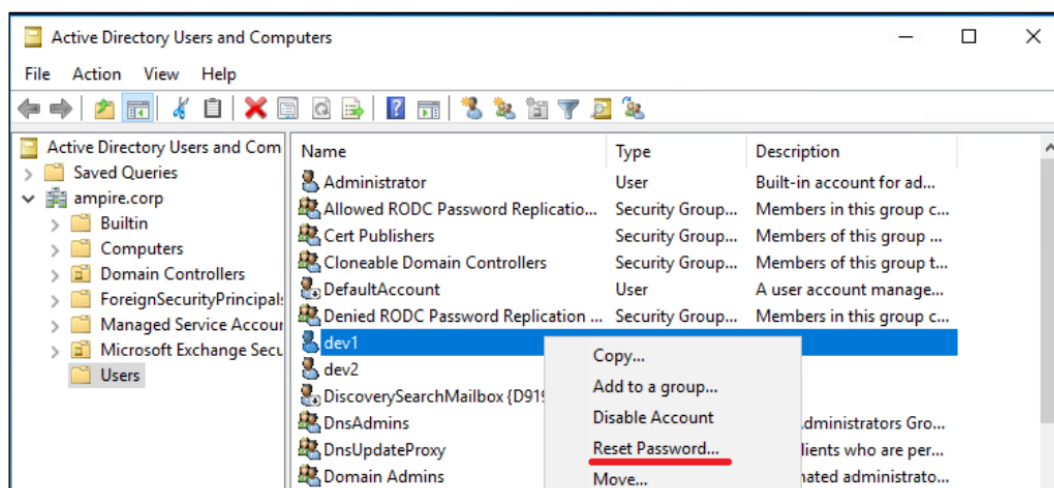


Рис. 2.1: Сброс пароля

После изменения пароля пользователя dev1 уязвимость успешно устранена.(рис. 2.2).

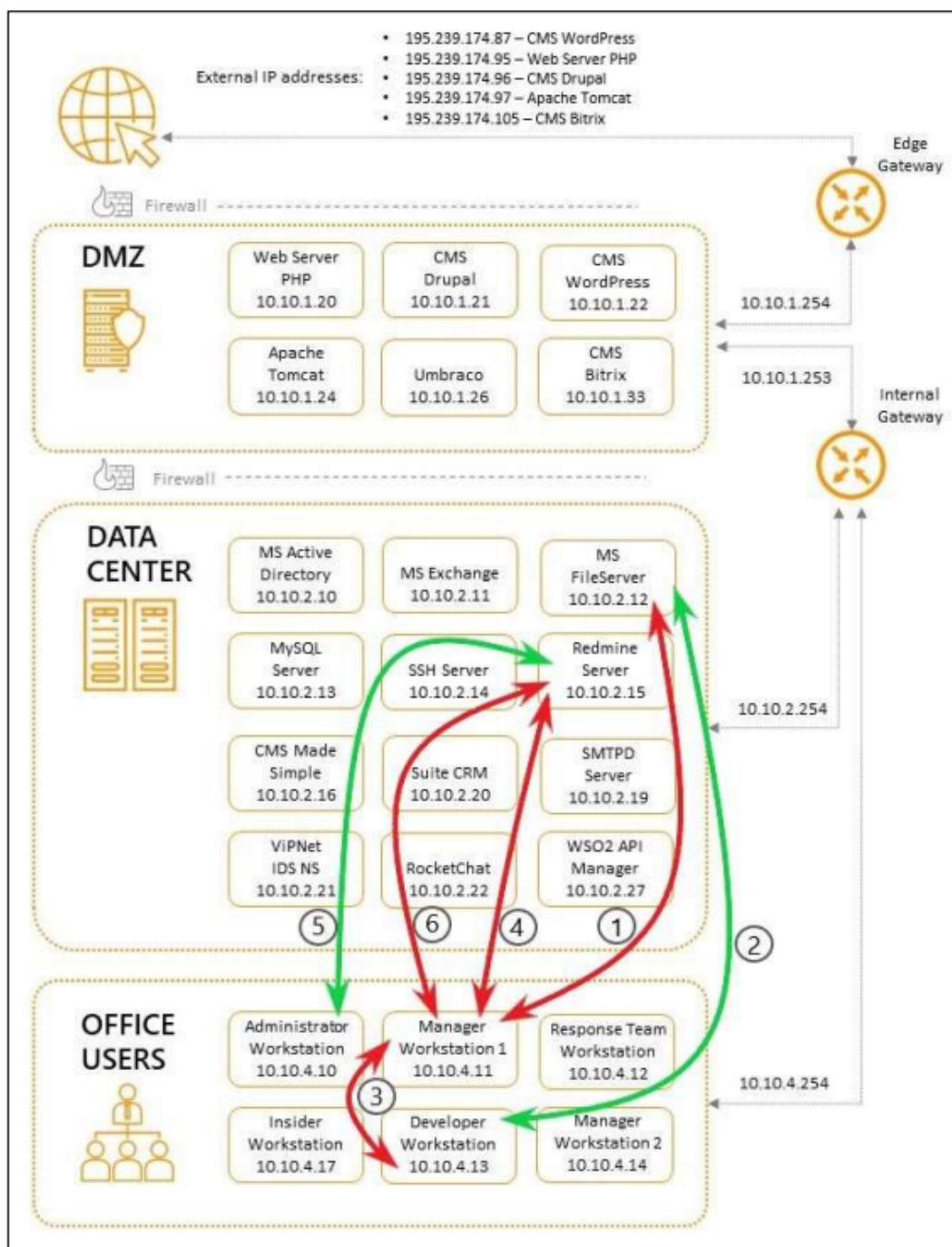


Рис. 2.2: Сброс пароля

Что было сделано:

2.2 Последствие. Developer backdoor.

Нарушитель может создать сервис, автоматически запускающий исполняемый файл, который устанавливает Reverse Shell подключение. Новая задача, записанная нарушителем, находится на узле Developer 1 (10.10.4.13) в планировщике задач. (рис. 2.3).

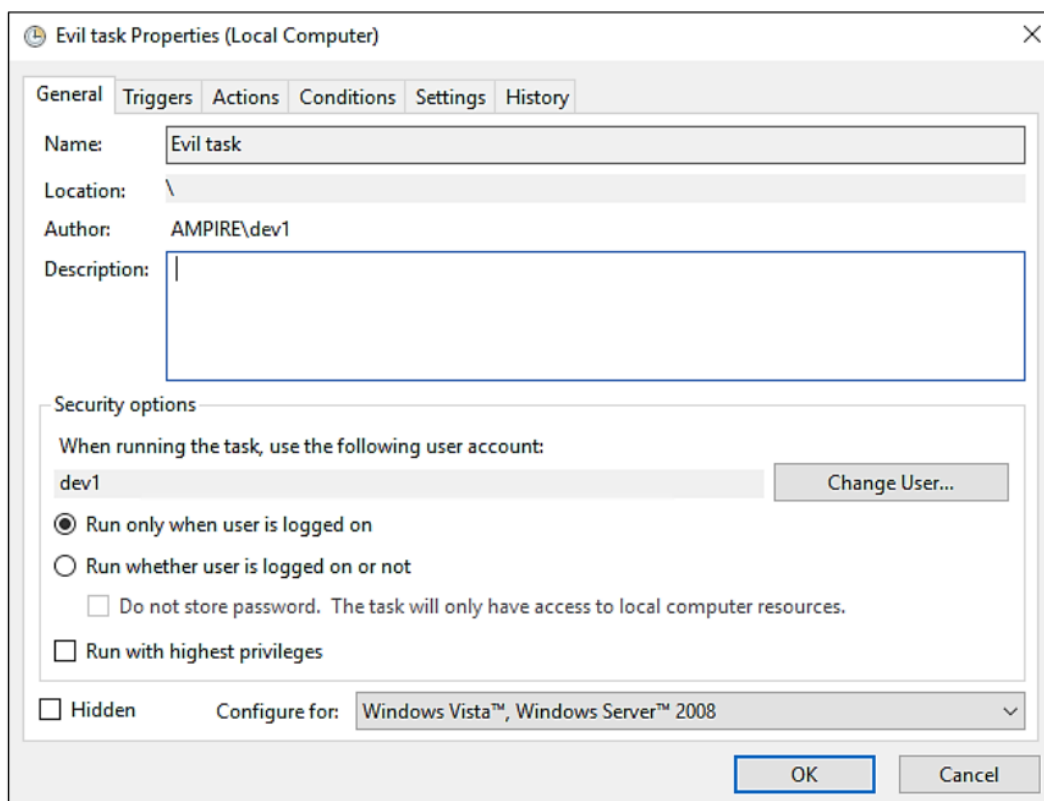


Рис. 2.3: Запуск исполняемого файла в планировщике

В созданной задаче можно обнаружить запуск файла во вкладке «Action» svchosting.exe (рис. 2.4).

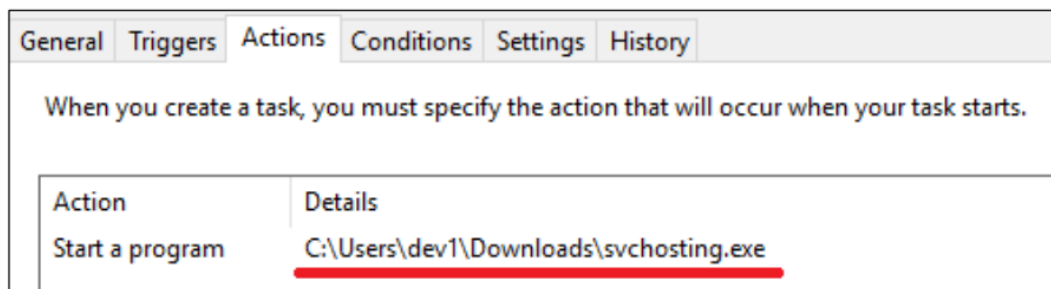


Рис. 2.4: Путь до исполняемого файла

Для устранения полезной нагрузки необходимо удалить задачу из планировщика задач и файл из директории (рис. 2.5).

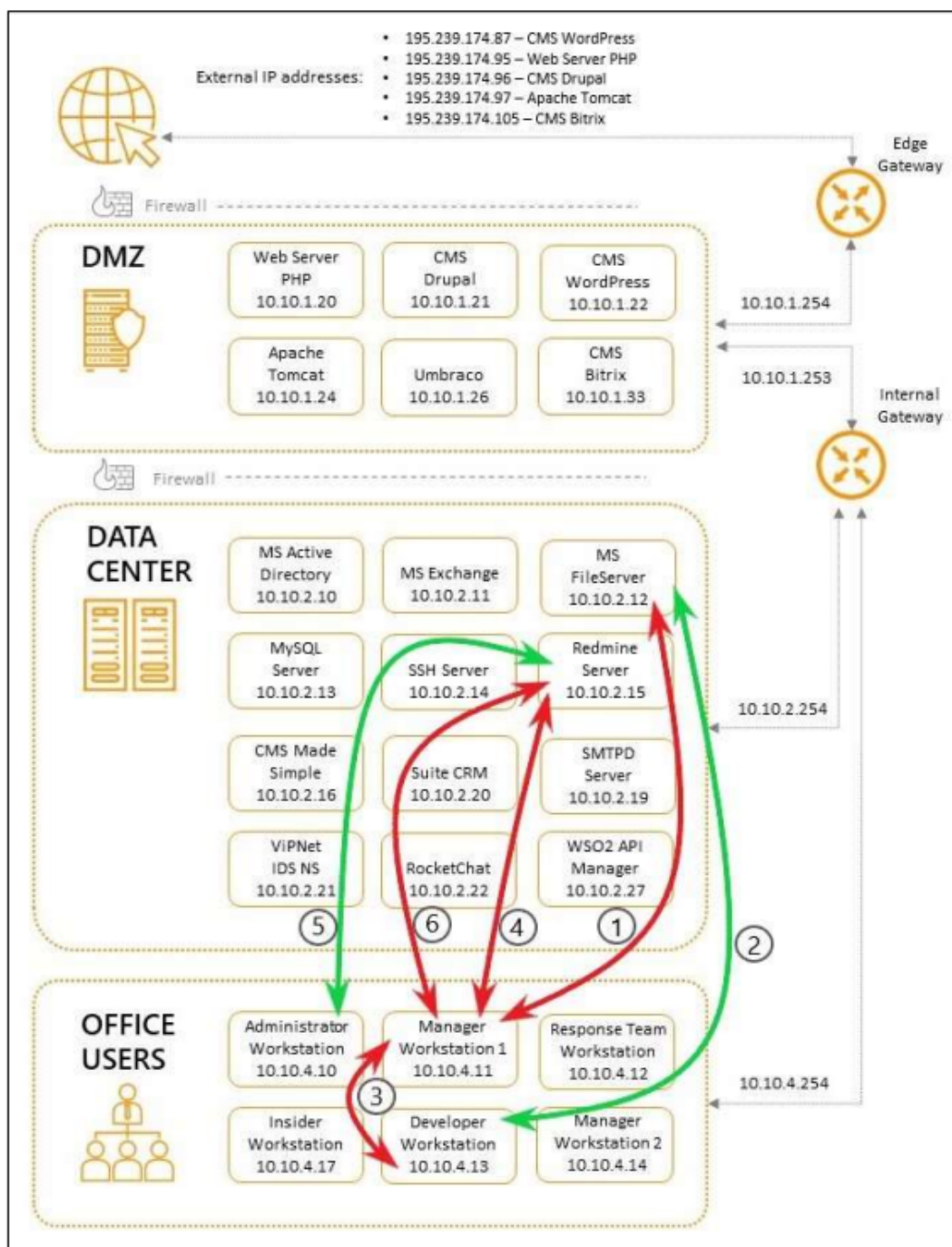


Рис. 2.5: Путь до исполняемого файла

Что было сделано:

2.3 Уязвимость 2. XSS (CVE-2019-17427).

Эксплуатируемая уязвимость – CVE-2019-17427.

В Redmine до версии 3.4.11 и 4.0.x до версии 4.0.4 постоянный XSS существует из-за ошибок форматирования при работе с textile текстом. В данном сценарии используется для включения REST API для эксплуатации следующей уязвимости (рис. 2.6), (рис. 2.7), (рис. 2.8).

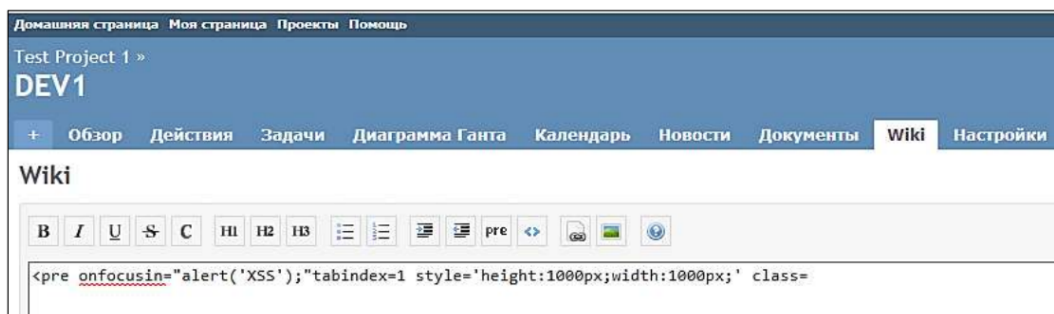


Рис. 2.6: Пример добавления кода, выводющего на экран надпись XSS в wiki-страницу

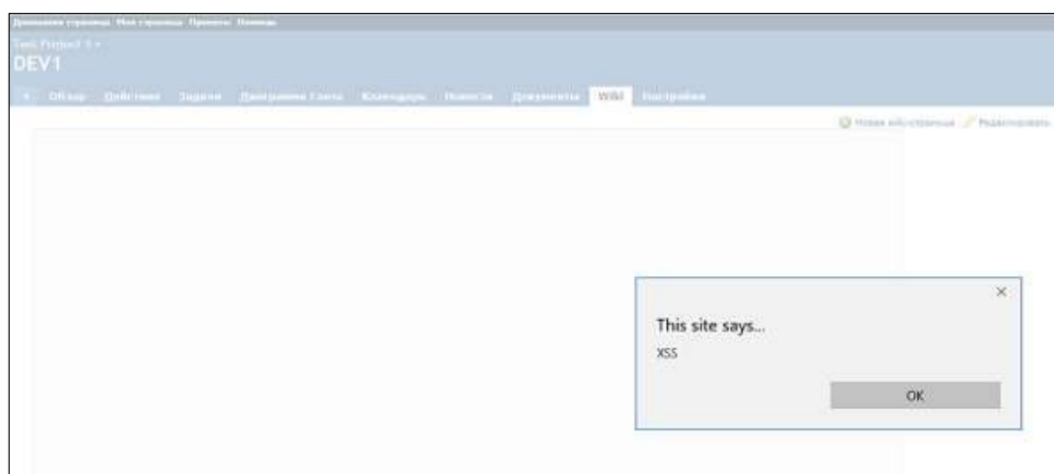


Рис. 2.7: При нажатии на поле wiki-страницы запускается код

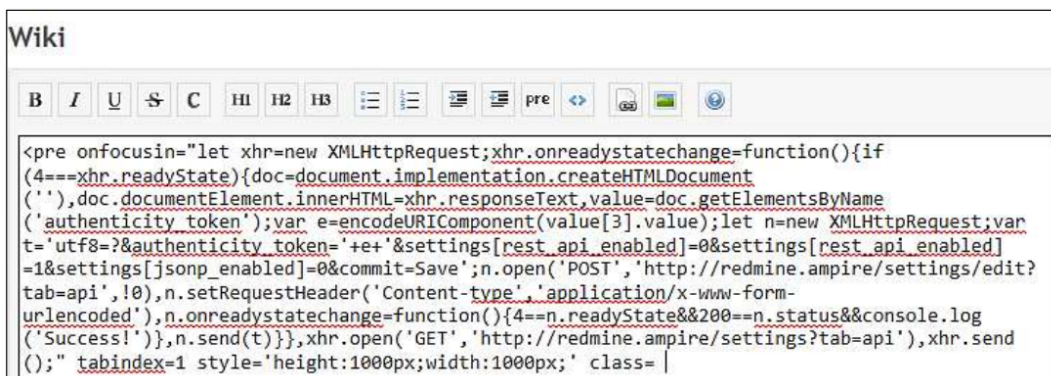


Рис. 2.8: Данный код включает REST API при выполнении с учетной записи admin

Решение: внести изменения в код Redmine.

Необходимо найти обработку текста wiki-страницы при наличии в тексте html-тегов. Из описания уязвимости понятно, что необходимо найти библиотеку для преобразования textile разметки в html. В Redmine за данное преобразование отвечает Redcloth (файл redcloth3.rb в папке /var/www/redmine/lib). В redcloth3.rb представляют интерес следующие строки (рис. 2.9).

```

1214 ALLOWED_TAGS = %w(redpre pre code kbd notextile)
1215 def escape_html_tags(text)
1216   text.gsub(/<(\s|\/?([!@&#'"`~\.\,\:\;\=\+\-\=\>\<])*)(>|<))/) {|m| ALLOWED_TAGS.include?(m[2]) ? "<#{m[1]}#{m[3]}" : "&lt;#{m[1]}#{m[3]}" unless m[3].blank?}
1217 end
1218 end

```

Рис. 2.9: Содержимое файла redcloth3.rb

Далее можно удалить тег pre из разрешенных тегов, которые не будут экранированы. Необходимо рассмотреть закрытие уязвимости разработчиками – в репозитории Redmine на Github зайти в Releases и сравнить исправленную версию с уязвимой. В файле redcloth3.rb разработчики внесли следующие изменения (рис. 2.10), (рис. 2.11), (рис. 2.12).

```

lib/redmine/wiki_formatting/textile/redcloth3.rb

@-1213,7 +1213,13 @@ def clean_html( text, tags = BASIC_TAGS )

  ALLOWED_TAGS = %w(redpre pre code kbd notextile)
  def escape_html_tags(text)
    text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?)) { |m| ALLOWED_TAGS.include?($2) ? "<#{m[1]}#{m[3]}" : "&lt;#{m[1]}#{m[3]}" unless $3.blank? }
    text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?)) do |m|
      if ALLOWED_TAGS.include?($2) && $3.present?
        "<#{m[1]}#{m[3]}"
      else
        "&lt;#{m[1]}#{m[3]}&gt;" unless $3.blank?
      end
    end
  end
end
end

```

Рис. 2.10: Изменения в файле redcloth3.rb Код, исправляющий уязвимость CVE-2019-17427

```

user@redmine: /var/www/redmine-3.3.4/lib
GNU nano 2.5.3 File: redcloth3.rb

        pcs << "#{prop}=\"#{l.gsub("'", '\\\'')}\""
        break
      end
    end
  end if tags[tag]
    "<#{raw[1]}#{pcs.join " "}">"
  else
    " "
  end
end
end
end

ALLOWED_TAGS = %w(redpre pre code kbd notextile)
def escape_html_tags(text)
  # text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?)) { |m| ALLOWED_TAGS.include?($2)
  text.gsub!(/<\/?([!\\w]+)[^<>\n]*(>?)) do |m|
    if ALLOWED_TAGS.include?($2) && $3.present?
      "<#{m[1]}#{m[3]}"
    else
      "&lt;#{m[1]}#{m[3]}&gt;" unless $3.blank?
    end
  end
end
end
end
end

```

Рис. 2.11: Исправление в файле redcloth3.rb

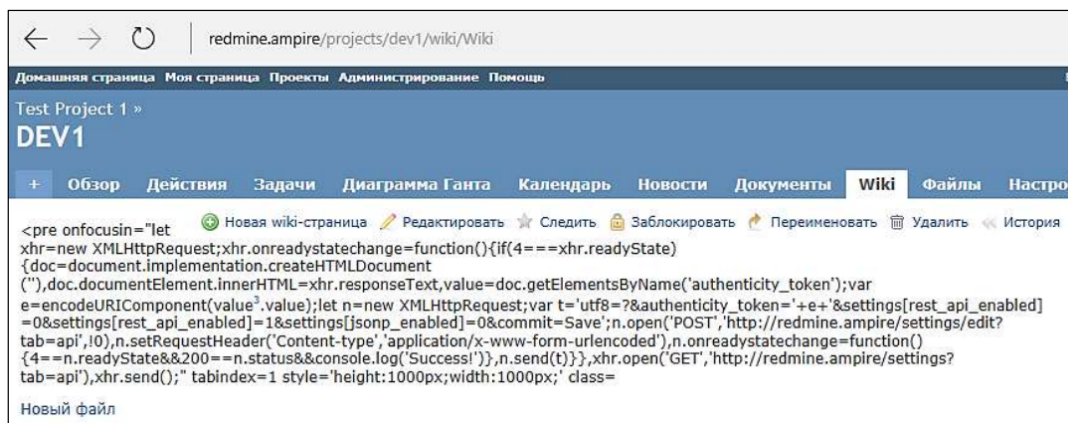


Рис. 2.12: Успешное устранение уязвимости

После внесения изменений необходимо перезапустить службу веб-сервера:
`sudo systemctl restart nginx.service.`

Что было сделано:

2.4 Последствие. Redmine User.

Данная полезная нагрузка заключается в том, что нарушитель создает пользователя на портале Redmine. Пользователь, обладающий правами администратора, имеет неограниченный доступ к пользовательской базе.

Примечание: способ закрытия полезной нагрузки «Redmine User» не будет действовать до внесения изменений по закрытию уязвимости «Атака XSS»

Для обнаружения добавления нового привилегированного пользователя, достаточно зайти в консоль администратора Redmine по ссылке (<http://redmine.ampire.corp/login>), перейти в раздел «Administration» – «Users» и посмотреть список существующих пользователей (рис. 2.13).

ребором с замером времени ответа. В данном сценарии данная уязвимость используется для получения конфиденциальной информации из БД, минуя разграничение доступа Redmine (рис. 2.15),(рис. 2.16).

Время прихода пакета является индикатором: при запоздании пакета – символ подобран верно, иначе – перебор продолжается.

F12 DOM Explorer Console Debugger Network Performance Memory Emulation Experiments						
Content type						
Name	Protocol	Method	Result	Content type	Received	Time
issues.xml?project_id=1&subproject_id=2,3-SLEEP(2) http://redmine.ampire/	HTTP	GET	200 OK	application/xml		4.09 s

Рис. 2.15: При отправке запроса SLEEP(2) время ожидания ответа возрастает до 4 секунд, что свидетельствует об инъекции

```

@433881.28977 (*) ProjectId 1 with a subproject was found successfully!
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "0A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "1A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "2A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "3A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "4A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "5A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "6A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "7A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "8A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "9A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "AA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "BA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "CA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "DA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "EA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "FA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "GA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "HA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "IA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "JA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "KA", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "LA", SLEEP(3), null))
c
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "0A", SLEEP(3), null))
http://redmine.ampire/issues.xml?project_id=1&subproject_id=2,3-IF (select description from issues where subject like "SECRETA" like "1A", SLEEP(3), null))

```

Рис. 2.16: Нарушитель посимвольно перебирает содержимое конфиденциального проекта

Решение: внести изменения в код Redmine.

Исходя из адреса и запроса следует найти местоположение скрипта, где происходит обработка параметра subproject_id. В данном случае рассмотрен файл query.rb. Данный файл находится в директории /var/www/redmine/app/models (рис. 2.17).

```
end

# Returns the SQL sort order that should be prepended for grouping
def group_by_sort_order
  if column = group_by_column
    order = (sort_criteria_order_for(column.name) || column.default_order || 'asc').try(:upcase)
    Array(column.sortable).map {|s| "#{s} #{order}" }
  end
end

# Returns true if the query is a grouped query
def grouped?
  !group_by_column.nil?
end

def group_by_column
  groupable_columns.detect {|c| c.groupable == c.name.to_s == group_by }
end

def group_by_statement
  group_by_column.try(:groupable)
end

def project_statement
  project_clauses = []
  if project == !project.descendants.active.empty?
    if has_filter?("subproject_id")
      case operator_for("subproject_id")
      when '='
        # include the selected subprojects
        # ids = [project.id] + values_for("subproject_id").each{|:to_i|
        ids = [project.id] + values_for("subproject_id").map{|:to_i|
      project_clauses << "(#{Project.table_name}.id IN (#{ids.join(',')})"
      when '!='
        # main project only
        project_clauses << "(#{Project.table_name}.id = #{project.id}
    else
```

Рис. 2.17: Содержимое файла query.rb с исправлением уязвимости

Из вышеупомянутого рисунка следует, что выделенный участок кода отвечает за передачу значений в запрос в случае наличия параметра subproject_id. В данном случае следует добавить фильтрацию значений и закомментировать код.

После внесения изменений необходимо перезапустить службу веб-сервера: `sudo systemctl restart nginx.service`.

Что было сделано:

3 Мониторинг

В процессе мониторинга, наша команда пыталась определить какие системы были затронуты нарушителем, что выдавало его присутствие большим числом откликов и связей между собой. У нас получилось установить 4 отчета мониторинга системы: от момента как нарушитель попал в систему, до описания всех уязвимостей что были в системе.

4 Вывод